Semana 5

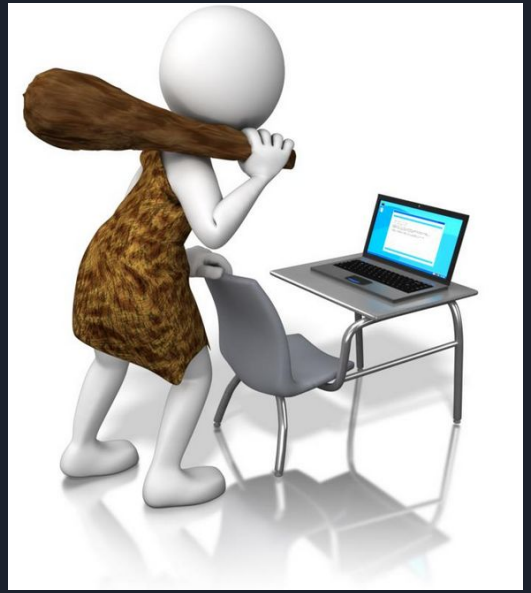
Fuerza Bruta

¿Qué es fuerza bruta?

Podríamos pensar que es intentar adivinar una clave a base de prueba y error

Y sí pero no…

Porque se hace con cierta metodología y sistema



¿Cómo?

¿Cuántas contraseñas puede haber?

Muchas xd

Peeeeeeeeeeeeeeroo

Podemos reducir el espacio a unas cuantas

Ejemplo: popularidad

123456, password, contraseña, qwerty, iloveyou, max, quesadilla, mexico123, etc

Tener una lista de posibles candidatas

A esta lista le llamaremos “wordlist”

Wordlists

Estas pueden ser obtenidas de distintas fuentes por ejemplo

- Páginas especializadas
- Contraseñas filtradas
- Estadísticas
- Creandolas
- “rainbow tables” (hashes)



La más famosa rockyou.txt con millones de ellas

Reducimos aún más las posibilidades

Vamos a aprovechar nuestra investigación

- Relaciones
- Gustos
- Lugares
- Pasatiempos

Junto con las famosas políticas de contraseñas

- Longitud mínima
- Una minúscula, una minúscula
- Un signo especial
- Un número

Para formas listas más eficientes

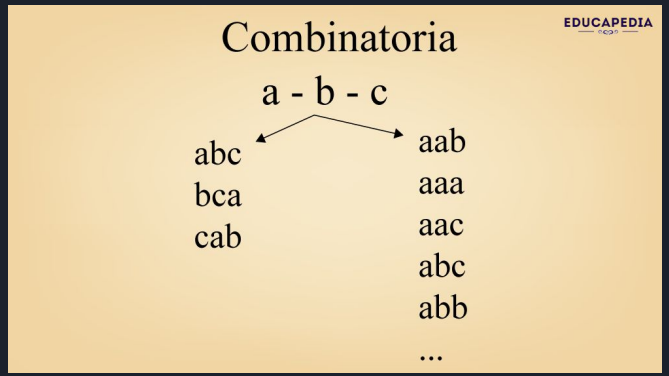
camila23 ✅, m!nutos31✅, C@rlos2004✅, Un@Mon0s1✅, badBunny2023 ✅, max ❌, luis ❌, marcosierra ❌,

Funcionamiento

Al final lo que hacemos es algo muy parecido a lo que hicieron en la práctica 3

$ [comando] [tipo/método] [opciones] [wordlist-pass]

* Cuantas más palabras más tardado



Nuestras herramientas

Hydra: Ataques de fuerza bruta en línea, generalmente los logins de una página web



hashcat: cracking de contraseñas fuera de línea, local

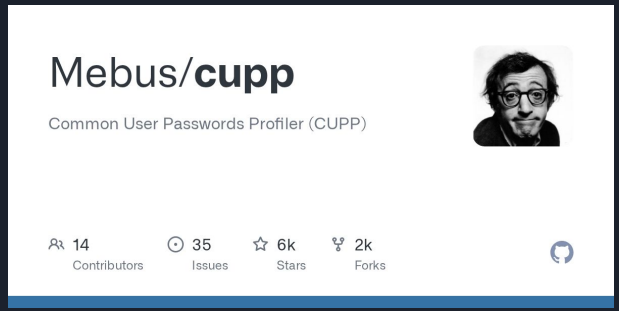


Nuestras herramientas

john the ripper: similar a hashcat pero más versátil (y también más lento)

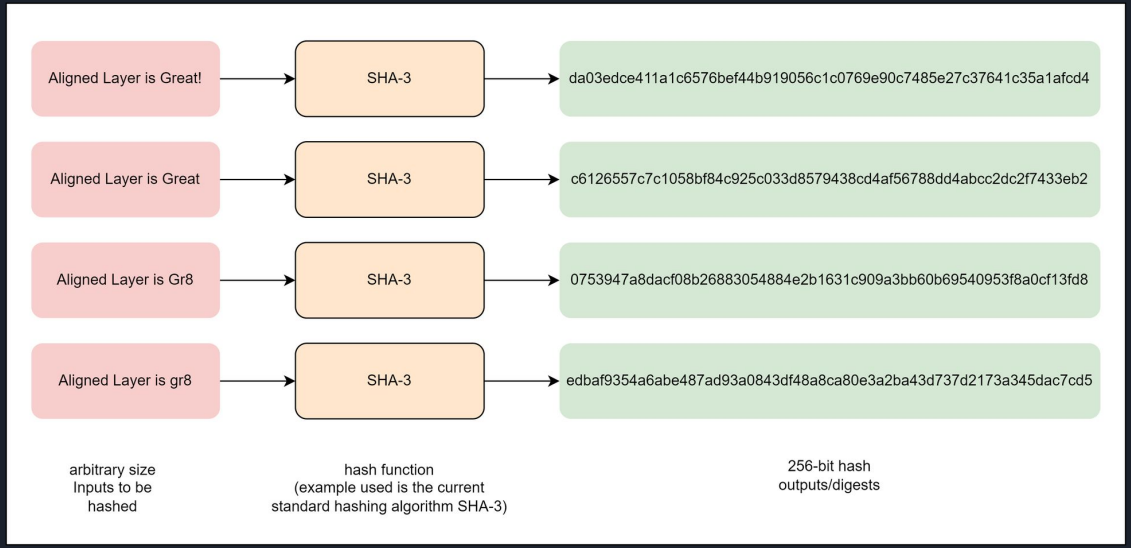


CUPP (Common User Passwords Profiler): generador de listas



Primero identificamos el hash

Cabe recalcar que estas herramientas no atacan directamente a la contraseña, sino a sus hashes. Esto porque en la BD de una página web las contraseñas no se guardan en texto plano sino que se guardan justo los hashes



Suelen tener el siguiente formato

$prefix$options$salt$hash

Donde

prefix es el algoritmo usado

optiones las opciones del algoritmo

salt la sal agragada a la contraseña

hash el hash en sí

Por ejemplo en /etc/shadow

Prefix	Algorithm
`$y$`	yescrypt is a scalable hashing scheme and is the default and recommended choice in new systems
`$gy$`	gost-yescrypt uses the GOST R 34.11-2012 hash function and the yescrypt hashing method
`$7$`	scrypt is a password-based key derivation function
`$2b$`, `$2y$`, `$2a$`, `$2x$`	bcrypt is a hash based on the Blowfish block cipher originally developed for OpenBSD but supported on a recent version of FreeBSD, NetBSD, Solaris 10 and newer, and several Linux distributions
`$6$`	sha512crypt is a hash based on SHA-2 with 512-bit output originally developed for GNU libc and commonly used on (older) Linux systems
`$md5`	SunMD5 is a hash based on the MD5 algorithm originally developed for Solaris
`$1$`	md5crypt is a hash based on the MD5 algorithm originally developed for FreeBSD

Lista completa en la documentación de hashcat:
https://hashcat.net/wiki/doku.php?id=example_hashes

Ejemplo 1 (hashcat)

hash: `$2a$06$7yoU3Ng8dHTXphAg913cyO6Bjs3K5lBnwq5FJyA6d01pMSrddr1ZG`

Vemos en la documentación que el modo es 3200

Una vez que hayamos identificado el tipo de hash escribimos el comando

$ hashcat -m 3200 -a 0 hash1.txt rockyou.txt

Ejemplo 2 (hashcat)

hash: `9eb7ee7f551d2f0ac684981bd1f1e2fa4a37590199636753efe614d4db30e8e1`

En este caso es SHA2-256 , vemos en la documentación que el modo es 1400

Una vez que hayamos identificado el tipo de hash escribimos el comando

$ hashcat -m 1400 -a 0 hash2.txt rockyou.txt

Ejemplo 3 (hashcat)

hash:
`$6$GQXVvW4EuM$ehD6jWiMsfNorxy5SINsgdlxmAEl3.yif0/c3NqzGLa0P.S7KRDYjycw5bnYkF5ZtB8wQy8KnskuWQS3Yr1wQ0`

Vemos en la documentación que el modo es 1800

Una vez que hayamos identificado el tipo de hash escribimos el comando

$ hashcat -m 1800 -a 0 hash3.txt rockyou.txt

Ejemplo 4 (John)

John es muy parecido, la diferencia es que debemos de obtener el hash del archivo original

Por ejemplo, si tenemos una llave id_rsa entonces sacamos su hash

$ /opt/john/ssh2john.py id_rsa > id_rsa_hash.txt

(Se puede obtener a través de

https://github.com/openwall/john.git)

Entonces ahora sí crackeamos el archivo id_rsa_hash.txt

$ sudo ~/john/run/john --wordlist=rockyou.txt hash.txt (--format=ssh)

Ejemplo 5 (John)

$ /opt/john/ssh2john.py id_rsa_alumn1 > id_rsa_prueba.txt

Entonces ahora sí crackeamos el archivo id_rsa_prueba.txt

$ sudo ~/john/run/john --wordlist=rockyou.txt id_rsa_prueba.txt

Práctica 5

Crackear hashes

Se dejará un formulario